UdeMM Universidad de la Marina Mercante

Informatic® Training Center

Análisis de vulnerabilidades

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

CLASE #30 — DIAGNÓSTICO Y MANTENIMIENTO DE PC

Cierre del módulo y del curso: amenaza, vulnerabilidad y riesgo, el proceso de gestión de vulnerabilidades en siete fases y cómo se clasifican y priorizan los hallazgos (CVSS, CVE).

© @gustavokempe

UdeMM Universidad de la Marina Mercante

Informatic® Training Center

Los fallos que nadie ve

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

Los fallos que nadie ve

Vulnerabilidad es la debilidad que una amenaza puede explotar. Toda organización tiene decenas sin saberlo: sistemas sin actualizar, contraseñas débiles, servicios abiertos que nadie usa.

El análisis de vulnerabilidades es el proceso periódico que encuentra, cataloga y ordena esos fallos para cerrarlos antes de que alguien los use.

- Vulnerabilidad: fallo explotable
- Amenaza: quien o qué aprovecha
- Riesgo: probabilidad por impacto
- El análisis las encuentra primero

© @gustavokempe

UdeMM Universidad de la Marina Mercante

Informatic Training Center

Los fallos que nadie ve

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC



Portada de la clase: análisis de vulnerabilidades

© @gustavokempe

UdeMM Universidad de la Marina Mercante | Informatic® Training Center

Amenaza, vulnerabilidad, riesgo

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

⚖️ Amenaza, vulnerabilidad, riesgo

La amenaza es el actor o suceso que puede dañar: un ransomware, un corte de luz, un empleado confundido. La vulnerabilidad es el fallo que la amenaza aprovecha.

El riesgo es la combinación: la probabilidad de que esa amenaza explote esa vulnerabilidad, más el peso de las consecuencias. No hay riesgo sin una vulnerabilidad aprovechable.

- Amenaza: el causante
- Vulnerabilidad: el fallo
- Riesgo: probabilidad + impacto
- Sin vulnerabilidad no hay riesgo

© @gustavokempe

Amenaza, vulnerabilidad, riesgo



Relación entre amenaza, vulnerabilidad y riesgo

© @gustavokempe

UdeMM Universidad de la Marina Mercante

Informatic Training Center

El proceso de gestión

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

🔄 El proceso de gestión

La gestión es un ciclo de siete fases: identificar los activos, planificar el análisis, ejecutarlo, clasificar lo encontrado, priorizar, remediar y validar el resultado.

Corregir todo de una vez rara vez es posible: por eso existen la clasificación y la priorización. El ciclo se repite de forma continua, no se hace una vez.

- Siete fases encadenadas
- Empieza por los activos
- Priorizar: no se puede todo
- Ciclo continuo, no puntual

© @gustavokempe

El proceso de gestión



Las siete fases del proceso de gestión de vulnerabilidades

© @gustavokempe

Identificar los activos

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

📋 Identificar los activos

Antes de escanear hay que saber qué existe: los procesos de negocio y su información crítica, las aplicaciones, el diagrama de red, los equipos con su responsable y los espacios físicos.

Los equipos iguales y con la misma configuración se agrupan: se analiza el grupo y el resultado sirve para todos sus integrantes.

- Procesos e información crítica
- Aplicaciones y red
- Equipos con responsable
- Agrupar configuraciones iguales

© @gustavokempe

Identificar los activos

FASE 1 · IDENTIFICAR ACTIVOS

Procesos de negocio	qué información necesita cada proceso para funcionar
Aplicaciones	su nivel de confidencialidad, integridad y disponibilidad
Diagrama de red	equipos, switch, router, access point e interconexiones
Equipos de IT	PCs, servidores, móviles, IoT, con ubicación y responsable
Espacios físicos	sala de servidores y locales donde vive lo crítico

Pueden agruparse como un grupo los equipos del mismo tipo y con la misma configuración.

Tipos de activos a identificar en la fase uno

© @gustavokempe

UdeMM Universidad de la Marina Mercante

Informatic® Training Center

El escáner de vulnerabilidades

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

📡 El escáner de vulnerabilidades

El análisis lo ejecuta un VAS (sistema automatizado de evaluación de vulnerabilidades): consulta a cada sistema y compara las respuestas contra una base de firmas de fallos conocidos.

Conviene evaluar desde afuera y desde adentro, usar credenciales privilegiadas para que el análisis llegue más profundo y probar antes en equipos de laboratorio: algunos VAS pueden corromper sistemas delicados.

- VAS: consulta y compara firmas
- Evaluar afuera y adentro
- Credenciales: análisis profundo
- Probar en equipo de laboratorio

© @gustavokempe

El escáner de vulnerabilidades

FASE 3 · EJECUTAR EL ANÁLISIS (VAS)

Un VAS (sistema automatizado de evaluación de vulnerabilidades) pregunta a cada sistema y compara la respuesta contra firmas d

- **Evaluar desde AFUERA (como un atacante en Internet) y desde DENTRO de la red**
- **Probar primero en copias: algunos VAS pueden corromper sistemas antiguos**
- **Usar credenciales privilegiadas: llega más profundo que un escaneo sin autenticación**
- **Escanear toda la red en busca de equipos desconocidos o no autorizados**
- **Supervisar la cuenta del escáner y deshabilitarla cuando no está en uso**

Buenas prácticas al ejecutar el análisis con el escáner

© @gustavokempe

UdeMM Universidad de la Marina Mercante

Informatic® Training Center

Clasificar con CVSS

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

📈 Clasificar con CVSS

El escáner asigna a cada hallazgo una gravedad con CVSS, un marco abierto que puntúa de 0 a 10: bajo (0.1 a 3.9), medio (4.0 a 6.9) o alto (7.0 a 10.0).

Ojo: la puntuación técnica no conoce el negocio. Un bajo en un servidor crítico puede doler más que un alto en un equipo aislado; por eso es un punto de partida, no la decisión final.

- CVSS: gravedad de 0 a 10
- Bajo, medio o alto
- No conoce el contexto del negocio
- Punto de partida, no sentencia

© @gustavokempe

Clasificar con CVSS



Escalas de gravedad del puntaje CVSS

© @gustavokempe

Priorizar

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

🎯 Priorizar

El orden típico: primero lo expuesto a Internet explotable de forma automática, después las aplicaciones web a medida visibles desde afuera.

Luego las estaciones de trabajo con descargas no autorizadas y, al final, los ataques que dependen de ingeniería social. El impacto técnico y el del negocio deciden el orden, no la etiqueta del escáner.

- Prioridad 1: servicios en Internet
- Prioridad 2: web a medida
- Prioridad 3: estaciones de trabajo
- Prioridad 4: ingeniería social

© @gustavokempe

Priorizar



Los cuatro niveles de prioridad para remediar

© @gustavokempe

UdeMM Universidad de la Marina Mercante

Informatic Training Center

CVE: el identificador

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

🕵 CVE: el identificador

Cada vulnerabilidad publicada recibe un identificador universal CVE con formato de año y número, por ejemplo CVE-2011-1269. Evita duplicados y permite coordinar acciones entre equipos de respuesta.

Con el identificador se consulta la base NVD y se sabe qué parche lo corrige: buscar el identificador más el nombre del software es la primera parada al investigar un aviso.

- CVE-AAAA-NNNN: identidad única
- Evita duplicados
- Coordina los equipos de respuesta
- NVD: base de consulta

© @gustavokempe

CVE: el identificador

CVE: LA DIRECCIÓN DE UNA VULNERABILIDAD

CVE-2011-1269

CVE-AAAA-NNNN
CVE = Common Vulnerabilities and Exposures: el número único que identifica a una vulnerabilidad publicada.

El identificador único evita duplicados y permite coordinar acciones entre CERTs

Hoy se consultan bases de vulnerabilidades como la NVD (National Vulnerability Database)

El escáner extrae estas entradas de la base para decir qué parche corrige cada CVE

Buscar el identificador + el nombre del software es la primera parada para ver si hay parche.

Identificador de ejemplo de una vulnerabilidad publicada

© @gustavokempe

Corregir, reconocer, investigar

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

✅ Corregir, reconocer, investigar

Cada hallazgo termina en una de tres decisiones. Corregir: parche o reconfiguración con fecha comprometida. Reconocer: dejarlo registrado con un motivo y una fecha de revisión.

Investigar: estado temporal hasta aclarar si es real, probable falso positivo o mala lectura del escáner. Siempre se anota quién decidió y por qué: es una decisión del negocio, no solo técnica.

- Corregir: con fecha comprometida
- Reconocer: motivo y revisión
- Investigar: estado temporal
- Registrar quién decidió

© @gustavokempe

Corregir, reconocer, investigar

LAS TRES DECISIONES POSIBLES

CORREGIR	parche, reconfiguración o mitigación, con fecha comprometida
RECONOCER	no se arregla AHORA: se registra el motivo y una fecha de revisión
INVESTIGAR	estado temporal hasta resolver si es corregir o reconocer (revisar posibles falsos po

Decidir es una decisión del negocio: cada opción pide registrar quién la tomó y por qué.

Las tres decisiones posibles ante cada hallazgo

© @gustavokempe

UdeMM Universidad de la Marina Mercante

Informatic® Training Center

Ejercicio: Cuestionario interactivo

DIAGNÓSTICO PC

Diagnóstico y Mantenimiento de PC

🧩 Cuestionario interactivo

Completar el cuestionario de 10 preguntas sobre vulnerabilidades, riesgo, el proceso de gestión y los identificadores CVE y CVSS.

- Abri el aula virtual de la clase y abrí el cuestionario interactivo.
- Responde las 10 preguntas eligiendo una sola opción en cada una.
- Al terminar, el sistema muestra cuántas acertaste y la explicación de cada respuesta.
- Si alguna salió mal, revisá la sección correspondiente del material teórico y volvé a intentarlo.

© @gustavokempe